

SECURITY EVENT AND INCIDENT ANALYSIS REPORT

Case Studies in Log-Based Incident Classification, Prioritization, and Response
Planning

Case Study 1 — Unauthorized SSH Login Attempts and Account Compromise

Case Study 2 — Insider Threat: Unauthorized Data Exfiltration via Removable Media

Discipline	Cybersecurity / Security Operations (SOC) & Incident Response
Framework Reference	NIST SP 800-61 Rev. 2 – Computer Security Incident Handling Guide
Document Type	Academic Case Study Assignment

Submitted By:

Abinesh M
192465050

Table of Contents

1.	Introduction and Conceptual Framework	3
2.	Case Study 1 — Unauthorized SSH Login Attempts	4
2.1	Scenario Overview	4
2.2	Network Architecture and Attack Path	4
2.3	Log Evidence Analysis	5
2.4	Event vs. Incident Determination	5
2.5	Incident Classification & Priority Assignment	6
2.6	Immediate Response Actions	6
3.	Case Study 2 — Insider Threat Data Exfiltration	7
3.1	Scenario Overview	7
3.2	Data Flow and System Architecture	7
3.3	Log Evidence Analysis	8
3.4	Event vs. Incident Determination	8
3.5	Incident Classification & Priority Assignment	9
3.6	Immediate Response Actions	9
4.	Comparative Analysis & Priority Matrix	10
5.	Conclusion	10

1. Introduction and Conceptual Framework

Modern Security Operations Centers (SOCs) continuously ingest large volumes of log data from servers, endpoints, firewalls, and applications. The core analytical challenge is not the collection of this data, but its correct interpretation: distinguishing routine, expected activity from activity that represents a genuine threat to the organization. This report examines two realistic scenarios, an external SSH brute-force attack and an internal data exfiltration case, to demonstrate the analytical process of event triage, incident classification, priority assignment, and immediate response planning.

1.1 Security Event vs. Security Incident

A **security event** is any observable occurrence within an information system, such as a login attempt, a file read, or a network connection. Events are recorded continuously and the overwhelming majority are benign. A **security incident**, by contrast, is one or more events that violate an organization's security policy or acceptable use policy, and that threaten the confidentiality, integrity, or availability (CIA triad) of an information asset. Every incident is built from events, but only a small fraction of events escalate into incidents. The analytical task of a SOC analyst is to apply context, such as source reputation, account privilege, timing, and behavioral baselines, to correctly separate the two.

1.2 Classification and Prioritization Approach

Both case studies in this report are analyzed using a consistent four-step method aligned with the NIST SP 800-61 Rev. 2 incident handling lifecycle: (i) identification of raw log evidence, (ii) determination of whether the activity constitutes an incident, (iii) classification of incident type and assignment of a priority level based on likelihood and business impact, and (iv) recommendation of immediate, actionable containment and response steps. This structured approach ensures that conclusions are evidence-driven rather than assumption-driven, and that response actions are proportionate to the assessed risk.

Figure 1.2 - NIST SP 800-61 Incident Response Lifecycle

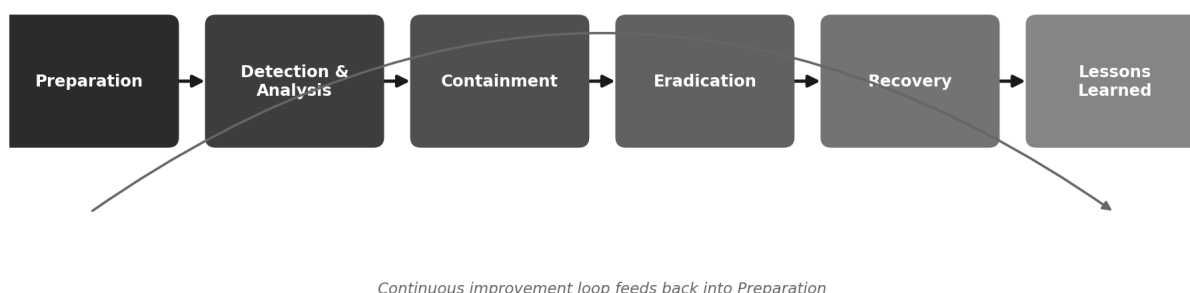


Figure 1 — The six-phase NIST incident response lifecycle applied throughout this report.

The remainder of this report is organized into two full case studies, each following the structure introduced above, followed by a comparative analysis section that positions both incidents on a shared priority matrix.

2. Case Study 1: Unauthorized SSH Login Attempts

2.1 Scenario Overview

An organization's Linux-based server records several failed SSH login attempts originating from a single external IP address within a short time window. Shortly afterward, one login attempt using an administrator account succeeds. The system administrator, reviewing `/var/log/auth.log`, notices the cluster of authentication failures and suspects unauthorized access. This is a textbook pattern of a brute-force or credential-stuffing attack that achieved a successful compromise of a privileged account.

2.2 Network Architecture and Attack Path

The diagram below illustrates the path of the attack traffic from the external attacker, through the organization's perimeter firewall, to the exposed SSH service on the target Linux server, alongside the authentication timeline extracted from `auth.log`.

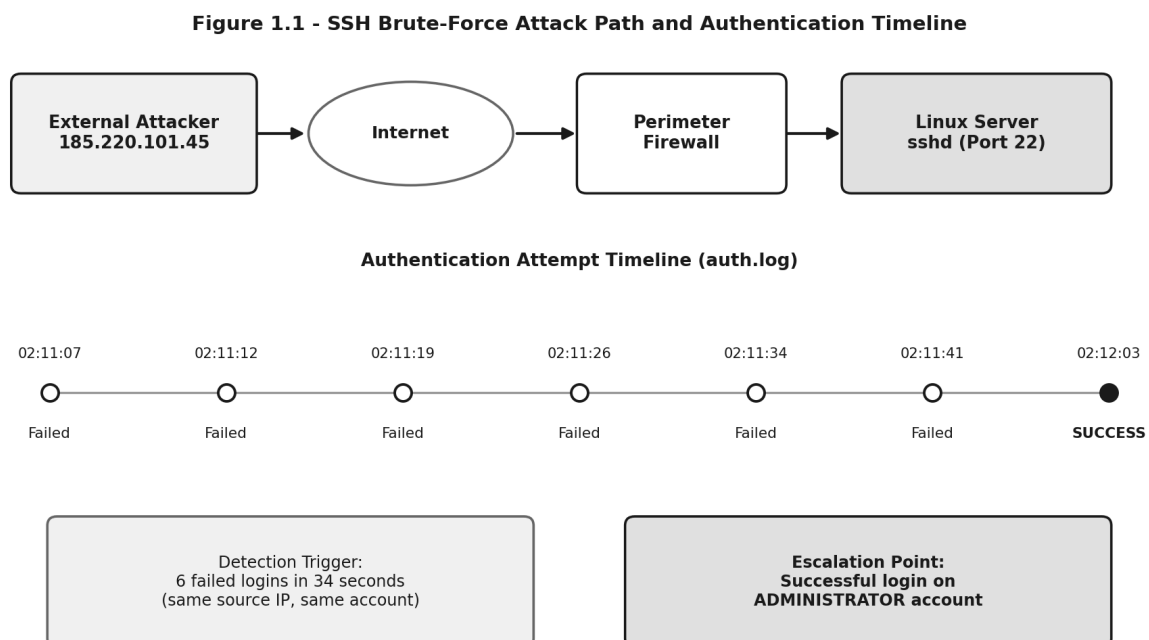


Figure 2 — Attack path from external source through the firewall to the SSH service, with the authentication attempt timeline reconstructed from `auth.log`.

2.3 Log Evidence Analysis

The following excerpt from `/var/log/auth.log` captures the relevant authentication sequence. Each failed attempt originates from the same source IP and targets the same account, followed by an accepted password event six seconds after the final failure:

```
Jul 14 02:11:07 srv01 sshd[2211]: Failed password for admin from 185.220.101.45 port 51122 ssh2
Jul 14 02:11:12 srv01 sshd[2213]: Failed password for admin from 185.220.101.45 port 51130 ssh2
Jul 14 02:11:19 srv01 sshd[2215]: Failed password for admin from 185.220.101.45 port 51138 ssh2
Jul 14 02:11:26 srv01 sshd[2217]: Failed password for admin from 185.220.101.45 port 51146 ssh2
Jul 14 02:11:34 srv01 sshd[2219]: Failed password for admin from 185.220.101.45 port 51155 ssh2
Jul 14 02:11:41 srv01 sshd[2221]: Failed password for admin from 185.220.101.45 port 51163 ssh2
Jul 14 02:12:03 srv01 sshd[2225]: Accepted password for admin from 185.220.101.45 port 51190 ssh2
Jul 14 02:12:03 srv01 sshd[2225]: pam_unix(sshd:session): session opened for user admin
```

Three evidentiary indicators stand out: (1) the six-to-seven second interval between failed attempts is far too regular for manual human typing, indicating an automated/scripted attack tool; (2) all attempts, failed and successful, originate from the identical external IP address, ruling out coincidental unrelated logins; and (3) the targeted account, admin, is a privileged account, meaning a successful compromise grants elevated control over the host.

2.4 Event vs. Incident Determination

Classification: Security Incident. Considered in isolation, repeated failed SSH logins are a common security event, most internet-facing servers receive automated login attempts constantly and this alone would not justify incident escalation. However, the immediately following **successful authentication on the administrator account from the same unrecognized external IP** changes the assessment entirely. This satisfies the definition of a security incident: unauthorized access has very likely occurred, directly threatening the confidentiality and integrity of the server and any data or services it hosts.

2.5 Incident Classification & Priority Assignment

Incident Category	Unauthorized Access / Account Compromise (Brute-Force Attack)
NIST Incident Category	CAT 6 – Unauthorized Access
Attack Vector	Remote network service – SSH (TCP port 22), external origin
Affected Asset	Linux production server; privileged administrator account
Priority Level	HIGH

Justification for High priority: The compromised account holds administrative privileges rather than standard-user privileges, meaning the attacker may now have root-level or equivalent control, sufficient to install backdoors, exfiltrate data, pivot to other internal systems, disable logging, or take the server fully offline. The sub-ten-second cadence between attempts confirms automated tooling rather than a legitimate user's mistyped password, and the external, non-whitelisted source IP eliminates the possibility of an internal administrator's own error. Under standard SOC severity matrices, the combination of "external attacker + privileged account + confirmed successful access" is treated as a top-tier, immediate-escalation event.

2.6 Immediate Response Actions

- **Contain:** Immediately disable/lock the compromised administrator account and forcibly terminate any active sessions tied to IP 185.220.101.45.
- **Block:** Add the source IP, and its associated subnet or ASN if part of a known malicious range, to the firewall and IPS deny-list.
- **Isolate:** If signs of post-compromise activity are found (new processes, unexpected cron jobs, modified SSH keys), disconnect the server from the network pending forensic review.
- **Preserve evidence:** Capture a forensic disk image and secure copies of auth.log, shell history, and any modified files before remediation, to maintain chain of custody.
- **Investigate:** Review for privilege escalation, newly created user accounts, modified authorized_keys files, and any outbound connections initiated after 02:12:03.
- **Reset credentials:** Force an immediate password reset on the affected account and rotate SSH keys for all administrator accounts on the host.

- **Harden controls:** Enable multi-factor authentication (MFA) for SSH access, disable direct administrative SSH login, and deploy an account lockout mechanism such as fail2ban.
- **Escalate and notify:** Formally escalate to the Incident Response team and notify the system owner and security leadership in line with the incident response plan.
- **Document:** Record a full incident timeline, all actions taken, and supporting evidence in the incident tracking system for post-incident review.

3. Case Study 2: Insider Threat – Data Exfiltration

3.1 Scenario Overview

A system administrator reviewing endpoint audit logs discovers that an employee accessed confidential financial records outside of normal working hours. The employee subsequently copied several sensitive files to a USB storage device without authorization, before disconnecting the device. No malware was detected on the endpoint at any point, but the pattern of behavior strongly suggests intentional, unauthorized data theft by an insider with legitimate system credentials.

3.2 Data Flow and System Architecture

The diagram below traces the path of the confidential data: from the finance file share, through the employee's workstation, and onto an unauthorized removable USB device, alongside the reconstructed off-hours activity timeline from the audit logs.

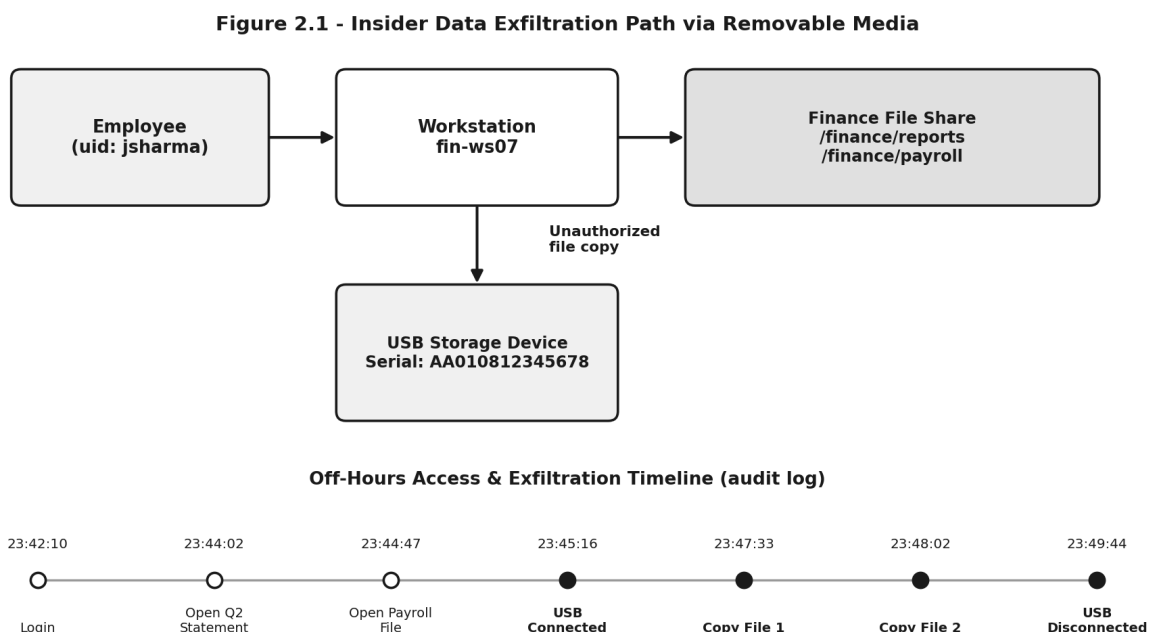


Figure 3 — Data exfiltration path from the finance file share to an unauthorized USB device, with the off-hours access and copy timeline.

3.3 Log Evidence Analysis

The endpoint audit trail below shows the employee logging in late at night, opening two confidential finance files outside their normal duties, connecting a USB storage device, copying both files to it, and disconnecting shortly after:

```

Jul 15 23:42:10 fin-ws07 audit: USER_LOGIN uid=jsharma exe=/usr/bin/login result=success
Jul 15 23:44:02 fin-ws07 audit: FILE_OPEN path=/finance/reports/Q2_Financial_Statement.xlsx uid=jsharma
Jul 15 23:44:47 fin-ws07 audit: FILE_OPEN path=/finance/payroll/Employee_Salary_2026.xlsx uid=jsharma
Jul 15 23:45:15 fin-ws07 kernel: usb 2-1: new high-speed USB device, VendorID=0781 ProductID=5581
Jul 15 23:45:16 fin-ws07 audit: USB_DEVICE_CONNECTED serial=AA010812345678 uid=jsharma
Jul 15 23:47:33 fin-ws07 audit: FILE_COPY src=/finance/reports/Q2_Financial_Statement.xlsx dst=/media/usb0/ uid=jsharma
  
```

```
Jul 15 23:48:02 fin-ws07 audit: FILE_COPY src=/finance/payroll/Employee_Salary_2026.xlsx  
dst=/media/usb0/ uid=jsharma  
Jul 15 23:49:44 fin-ws07 audit: USB_DEVICE_DISCONNECTED serial=AA010812345678 uid=jsharma  
Jul 15 23:50:01 fin-ws07 audit: USER_LOGOUT uid=jsharma
```

Four evidentiary indicators are significant here: (1) all activity occurs between 23:42 and 23:50, well outside standard business hours; (2) the files accessed, a quarterly financial statement and an employee payroll file, fall outside the employee's ordinary working scope; (3) a previously unregistered USB device is connected immediately before the file copy operations and disconnected immediately after, consistent with a deliberate, short-duration exfiltration action; and (4) no malware indicators were present, confirming this is a policy and trust violation by an authorized user rather than an external technical compromise.

3.4 Event vs. Incident Determination

Classification: Security Incident. File access and USB connections are, in isolation, routine security events. What elevates this activity to an incident is the convergence of off-hours timing, access to specifically confidential financial and payroll records, and immediate transfer to unauthorized removable media. This combination represents a clear confidentiality violation and a breach of acceptable data handling policy. Incidents are defined by policy violation and potential impact, not by the presence of malicious code, so the absence of malware does not reduce this to a mere event.

3.5 Incident Classification & Priority Assignment

Incident Category	Insider Threat – Unauthorized Data Exfiltration
NIST Incident Category	CAT 6 – Unauthorized Access / Data Loss (policy violation by an authorized user)
Attack Vector	Physical / local – removable media (USB), performed by an insider with valid credentials
Affected Asset	Confidential quarterly financial statement; employee payroll data
Priority Level	HIGH

Justification for High priority: Although the actor used legitimate credentials and no malware was involved, the data categories affected, financial reporting and payroll information, typically carry significant regulatory, legal, and reputational sensitivity, including potential compliance exposure and employee privacy obligations. Access to files entirely outside the employee's normal working scope, conducted at night, is a strong behavioral indicator of deliberate intent rather than accidental access. Because the data has already left the controlled digital environment on physical removable media, this case carries elevated urgency: unlike many network-based incidents, the exposure cannot be remotely contained once the device has left the premises.

3.6 Immediate Response Actions

- **Contain:** Suspend the employee's system and network account access and revoke remote/VPN privileges pending investigation, coordinated with HR.
- **Preserve evidence:** Forensically image the endpoint (fin-ws07) and preserve all relevant audit logs; do not reissue or wipe the machine.
- **Recover the device:** Coordinate with HR, Legal, and Security to recover the physical USB device from the employee; if unrecoverable, treat this as confirmed active data loss.
- **Assess scope:** Determine precisely which files were accessed and copied, their sensitivity classification, and whether regulatory notification obligations apply.

- **Engage stakeholders:** Immediately notify HR, Legal counsel, and the Data Protection Officer, since insider incidents carry HR and legal dimensions beyond technical remediation.
- **Review controls:** Audit the employee's access rights against least-privilege principles, and review why the Data Loss Prevention (DLP) tooling did not block or alert on this transfer.
- **Harden controls:** Deploy or tighten DLP and USB-restriction policies organization-wide, and enable alerting on off-hours access to sensitive file shares.
- **Investigate:** Conduct a formal investigation interview with the employee under HR/Legal guidance, and review their historical access patterns for prior anomalies.
- **Document and report:** Record the complete evidentiary timeline for potential disciplinary, civil, or law-enforcement action, and update the organization's incident register.

3.7 Analyst Notes: Distinguishing Insider Threat Sub-Types

Insider threats are generally grouped into three sub-types, which matters for how the response team calibrates its investigation. A **malicious insider** acts with deliberate intent to harm the organization or benefit personally, as the off-hours timing and targeted file selection in this case suggest. A **negligent insider** causes harm through carelessness, for example backing up work files to personal media without realizing the policy violation, with no intent to misuse the data. A **compromised insider** is a legitimate account being puppeted by an external attacker, typically distinguishable through anomalous login geography or device fingerprints, which are absent in this case. Because malicious intent cannot be confirmed from log evidence alone, the response team should formally investigate before making disciplinary or legal determinations, while still treating the technical exposure itself as fully realized regardless of the eventual intent finding.

4. Comparative Analysis & Priority Matrix

Although the two cases differ fundamentally in origin, one external and technical, the other internal and behavioral, both were assessed at High priority. Plotting them on a shared likelihood-versus-impact matrix makes this consistency visually explicit and highlights that priority assignment depends on the sensitivity of the affected asset and the confirmed likelihood of compromise, not on the sophistication of the attack technique.

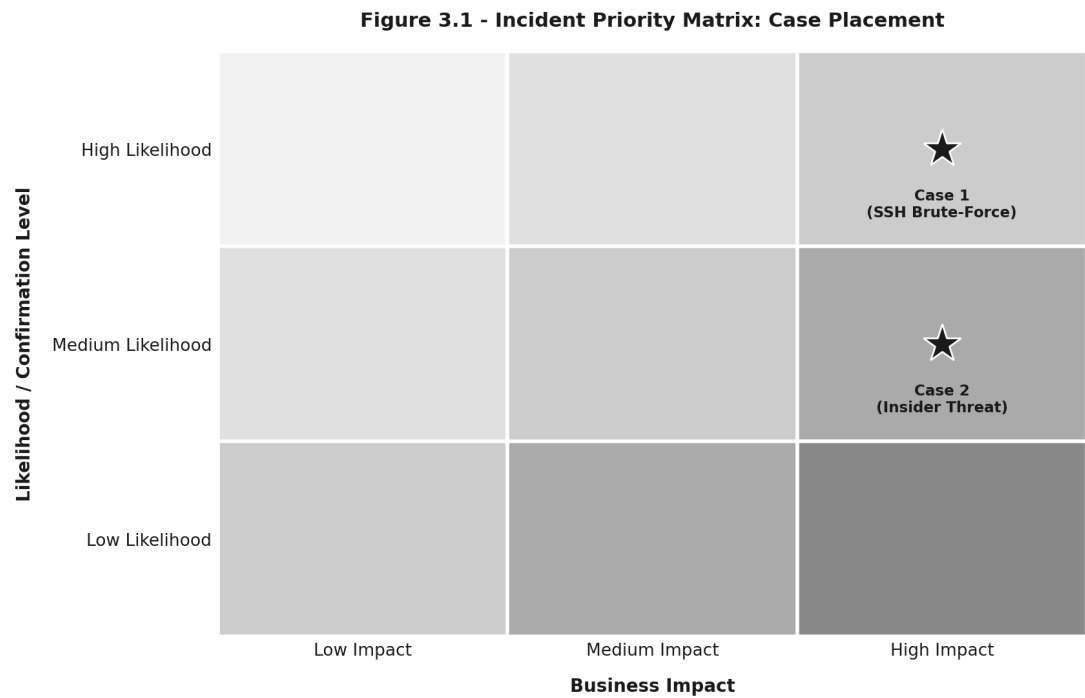


Figure 4 — Both incidents land in the high-likelihood, high-impact quadrant of the priority matrix, despite differing attack vectors.

4.1 Side-by-Side Summary

Aspect	Case 1: SSH Brute-Force	Case 2: Insider Threat
Classification	Security Incident	Security Incident
Incident Type	Unauthorized Access (external)	Data Exfiltration (insider)
Priority Level	High	High
Primary Evidence	Repeated failed logins followed by a successful admin login from an external IP	Off-hours file access followed by unauthorized USB copy of confidential files
Actor	Unknown external threat actor	Known internal employee (trusted insider)
Detection Source	/var/log/auth.log (sshd events)	Endpoint audit log (file & USB events)
Root Cause	Weak/guessable password, absence of MFA and account lockout policy	Excessive access privileges, insufficient DLP / USB controls

Containment Difficulty	Moderate – network-based, can block IP and reset credentials remotely	High – data already left the digital environment on physical media
-------------------------------	---	--

4.2 Common Themes

Both cases reinforce that classification and prioritization are driven primarily by two factors: the sensitivity of the asset involved, and the degree to which available evidence confirms rather than merely suggests compromise or intent. In Case 1, the technical certainty of a successful authenticated session on a privileged account confirmed compromise. In Case 2, the behavioral convergence of timing, file sensitivity, and removable media use confirmed intent even without any malicious code being present. In both scenarios, the fundamentals of sound incident response, rapid containment, rigorous evidence preservation, and cross-functional escalation spanning technical, HR, and legal stakeholders where relevant, are essential to limiting organizational damage.

5. Conclusion

This report analyzed two distinct but equally severe security scenarios using a consistent, evidence-based classification methodology. Case 1 demonstrated how automated external attack patterns, visible through authentication timing and source IP correlation in auth.log, can culminate in a confirmed account compromise requiring High-priority network-focused containment. Case 2 demonstrated that insider threats, lacking any malware signature, can be equally severe when off-hours behavior, file sensitivity, and removable media usage converge into a clear policy violation. Both cases illustrate that effective SOC analysis depends on correlating multiple log sources and contextual factors, rather than reacting to any single log line in isolation, and that a well-prepared incident response plan must address both external technical threats and internal behavioral threats with equal rigor.

From a policy standpoint, both cases point toward the same set of preventive investments: strong authentication controls (MFA and account lockout) to reduce the success rate of credential-based attacks, and Data Loss Prevention combined with least-privilege access reviews to reduce the blast radius of insider misuse. Equally important is the maturity of logging itself, both incidents were only detectable because auth.log and endpoint audit logging were enabled, correctly timestamped, and retained long enough for an analyst to reconstruct the full sequence of events. Organizations that under-invest in log retention, centralized log aggregation (e.g., a SIEM), and regular log review lose the ability to detect either category of incident until the damage has already fully materialized. A recurring takeaway for SOC training is therefore that priority levels should be assigned based on confirmed impact and asset sensitivity, not on the technical complexity of the attack, since a simple insider file copy can carry the same organizational risk as a sophisticated external intrusion.